

Suricata NSM: More than an IDS Cheat Sheet（日本語訳）

Suricataによるネットワークセキュリティ監視（NSM）

はじめに

- 数ステップで簡単に導入可能
 - 1つの目的（ネットワーク監視）に特化した設計
 - 多くのプラットフォームへ簡単にインストール可能
 - ネットワーク構成に合わせて柔軟に設定可能
 - ルールの作成・調整・更新・削除が可能
 - SplunkなどのSIEMへログ転送可能
-

ソースコードからのビルド

```
tar xzvf suricata-6.0.0.tar.gz
cd suricata-6.0.0
./configure
make && sudo make install
```

リポジトリからインストール

```
sudo add-apt-repository ppa:oisf/suricata-stable
sudo apt update
sudo apt install suricata jq
sudo suricata --build-info
sudo systemctl status suricata
sudo vim /etc/suricata/suricata.yaml
sudo systemctl restart suricata
```

設定確認

```
suricata --build-info | grep -A 3 '--prefix'
suricata --dump-config
suricata --list-app-layer-protos
```

確認できる内容

- ビルドオプション
- 現在の設定値
- サポートするアプリケーション層プロトコル

IDSモードとIPSモード

```
# LISTENMODE=af-packet    # IDS
# LISTENMODE=nfqueue      # IPS
```

コメントアウト（#）を外して有効化します。

モード	説明
IDS	検知のみ
IPS	検知 + 遮断

Suricata主要ファイル

ファイル	用途
classification.config	classtype定義
rules/*.rules	ルールファイル
rules/custom.rules	自作ルール
suricata.yaml	メイン設定
threshold.config	アラート制御
variables.config	変数定義

ログ監視

ログ保存先

```
/var/log/suricata
```

アラート確認

```
tail -f /var/log/suricata/fast.log
```

HTTPリクエスト確認

```
tail -f /var/log/suricata/http.log
```

Suricata状態確認

```
tail -f /var/log/suricata/suricata.log
```

統計情報

```
tail -f /var/log/suricata/stats.log
```

JSONログ (eve.json)

全アラート確認

```
jq 'select(.event_type=="alert")' \  
/var/log/suricata/eve.json
```

SID指定

```
jq 'select(.alert.signature_id==2100498)' \  
/var/log/suricata/eve.json
```

統計確認

```
jq 'select(.event_type=="stats")' \  
/var/log/suricata/eve.json
```

カーネルパケット数

```
jq 'select(.event_type=="stats") |  
.stats.capture.kernel_packets' \  
/var/log/suricata/eve.json
```

トラブルシューティング

設定ファイルテスト

```
sudo suricata \  
-c /etc/suricata/suricata.yaml \  
-T -vvv
```

正常なら

```
Configuration provided was successfully loaded.
```

と表示されます。

再起動

```
sudo systemctl restart suricata
```

状態確認

```
sudo systemctl status -l suricata
```

SID検索

```
grep -Ril <SID番号>
```

ルール作成の考え方

良いルール

- Exploitではなく脆弱性を検知する
- 深夜など異常時間帯を検知する
- 不要な通信を除外する
- ネットワーク範囲を考慮する
- 異常ポートや異常プロトコルを検知する
- テストとチューニングを行う

対応プロトコル

基本プロトコル

```
icmp  
tcp  
udp  
ip
```

※ ip = 全プロトコル対象

アプリケーション層

```
dcerpc  
dhcp  
dnp3  
dns  
enip  
ftp  
http
```

```
http2
ikev2
imap
krb5
modbus
nfs
ntp
rdp
sip
smb
smtp
snmp
ssh
tftp
tls
```

※ ModbusはICS/OT環境でよく利用されます。

Suricataルールの3要素

① Action

ルールに一致した時の動作

② Header

通信条件

③ Options

詳細条件

Action一覧

Action	意味
alert	アラート生成
pass	許可して検査終了
drop	通信遮断（IPS）
reject	RST/ICMP返信後に遮断

Action	意味
rejectsrc	送信元へRST
rejectdst	宛先へRST
rejectboth	双方へRST

Header構文

```
<protocol> <src_ip> <src_port>  
->  
<dst_ip> <dst_port>
```

例

```
ip any any -> any any
```

```
tcp $EXTERNAL_NET any ->  
$HOME_NET 80
```

双方向通信

```
<>
```

Options

利用例

- msg
 - content
 - flow
 - classtype
 - sid
 - rev
-

Classtype

トラフィックを分類する機能

例

```
bad-unknown
```

意味

潜在的に危険な通信

Priority

優先度

```
1 ~ 255
```

数値が小さいほど重要

Reference

CVEやMITRE ATT&CKとの紐付け

CVE

```
reference:cve,2014-0160;
```

ATT&CK

```
reference:tcode,1194;
```

SID割り当て

範囲	用途
1000000-1999999	カスタム
2000000-2099999	Emerging Threats
2100000-2103999	Forked Snort GPL
2200000-2200999	Decoder Events
2210000-2210999	Stream Events
2800000-2899999	ET Pro

ICMP Ping検知ルール

```
alert icmp any any -> any any
(msg:"PING detected";
sid:2;
rev:1;)
```

意味

- ICMP通信検知
- アラート生成
- SID=2

HTTP GET検知例

```
alert http $HOME_NET any ->
$EXTERNAL_NET any
(
msg:"HTTP GET Request Containing Rule in URI";
flow:established,to_server;
http.method;
content:"GET";
http.uri;
content:"rule";
fast_pattern;
classtype:bad-unknown;
sid:123;
```

```
rev:1;  
)
```

意味

URIに

```
rule
```

を含むGETリクエストを検知

ルール再読み込み

方法1

```
systemctl restart suricata
```

方法2

```
kill -USR1 $(pidof suricata)
```

方法3（推奨）

```
suricatasc -c reload-rules
```

ルール動作テスト

```
curl http://testmynids.org/uid/index.html
```

確認

```
grep 2100498 \  
/var/log/suricata/fast.log
```

Threshold（アラート制御）

60秒に1回のみ

```
threshold gen_id 1,  
sig_id 2404000,  
type threshold,  
track by_dst,  
count 1,  
seconds 60
```

送信元ごとに60秒間で10回

```
threshold gen_id 0,  
sig_id 0,  
type threshold,  
track by_src,  
count 10,  
seconds 60
```

Suppress（アラート抑制）

特定ホストを除外

```
suppress gen_id 0,  
sig_id 0,  
track by_src,  
ip 1.2.3.4
```

オフライン解析

PCAPファイルを直接解析

```
sudo suricata \  
-c /etc/suricata/suricata.yaml \  
-i /dev/null
```

```
-r sample.pcap \  
-l output_dir
```

利点

- インシデント調査
- マルウェア通信解析
- ルール検証
- フォレンジック分析

学習に役立つサイト

- Suricata Documentation
- Suricata User Guide
- Emerging Threats Rules
- ET Rule SID Lookup
- Talos VRT Rules
- Oinkmaster
- Snorpy Rule Generator
- Suricata Configuration Guide

試験・実務向け補足

SplunkやSecurity Onionでよく見るのは **eve.json** です。

特に以下の event_type は重要です。

event_type	内容
alert	検知イベント
http	HTTP通信
dns	DNS通信
tls	SSL/TLS通信
flow	通信セッション
fileinfo	ファイル転送

event_type	内容
stats	統計情報